POPIA and Digital Privacy Module
Section 4: What Organisations Must Do Under POPIA

PART A: LEARNING CONTENT

Introduction

In the previous sections you learned what POPIA is, what rights it gives you, and how personal data gets misused. This section shifts the focus to the other side of the relationship: the organisations that collect and use your data. POPIA places clear legal obligations on every organisation that handles personal information. Understanding what organisations are supposed to do helps you recognise when they are falling short and gives you the confidence to hold them accountable.

The 8 Conditions for Lawful Processing of Personal Information

Condition 1: Accountability

The responsible party must ensure that all the conditions for lawful processing are met. They are accountable for everything that happens to the personal information they collect, including what their operators do with it on their behalf.

Condition 2: Processing Limitation

Personal information may only be collected and processed for a specific, lawful purpose. The processing must be adequate, relevant, and not excessive in relation to the purpose. For example, a food delivery app needs your address to deliver food. It does not need your ID number or employment details.

Condition 3: Purpose Specification

The organisation must be clear and upfront about the specific purpose for which your personal information is being collected. They must also ensure that your information is not kept for longer than is necessary to achieve that purpose.

Condition 4: Further Processing Limitation

If an organisation wants to use your personal information for a purpose other than the one it was originally collected for, that new purpose must be compatible with the original purpose. They cannot collect your data for one reason and then quietly use it for something entirely different.

Condition 5: Information Quality

The organisation is responsible for making sure that the personal information they hold about you is accurate, complete, and up to date. They cannot knowingly store incorrect information about you.

Condition 6: Openness

Organisations must be transparent about their information processing activities. They must have a privacy policy that clearly explains what information they collect, why they collect it, how long they keep it, and who they share it with.

Condition 7: Security Safeguards

The responsible party must put appropriate technical and organisational measures in place to protect your personal information against loss, damage, unauthorised access, and unlawful processing. This includes encryption, secure servers, access controls, and staff training.

Condition 8: Data Subject Participation

Organisations must give you the ability to exercise your rights as a data subject. They must have a process for you to request access to your information, request corrections, or request deletion.

What Universities and Apps Must Do Before Collecting Your Data

They must identify a lawful purpose

Every organisation must have a clear and legitimate reason for every piece of information it requests from you.

They must notify you

Before collecting your information, they must inform you of who they are, what information they are collecting, why they are collecting it, whether it is mandatory or voluntary, and who else might have access to it.

They must obtain consent where required

In many cases, organisations must obtain your consent before processing your personal information. This consent must be freely given, specific, and informed.

They must appoint an Information Officer

Every organisation that processes personal information is required to appoint an Information Officer who is responsible for ensuring POPIA compliance.

How to Read a Privacy Policy

A privacy policy is a document that an organisation publishes to explain how they handle your personal information. Here is what a proper privacy policy should contain:

- The full name and contact details of the organisation
- What personal information is collected and why
- The legal basis for collecting and processing your information
- How long your information will be kept
- Who your information is shared with and under what circumstances
- How your information is protected
- How you can exercise your rights as a data subject
- Contact details for the Information Officer

Warning signs in a bad privacy policy:

- Vague language like "we may share your information with selected partners" without specifying who
- No mention of how long your data is kept
- No information about how to request access or deletion of your data
- A clause stating they can change the policy at any time without notifying you
- No contact details for complaints or queries

How to Report a POPIA Violation to the Information Regulator

Step 1: Contact the organisation in writing and explain the issue. Give them a reasonable opportunity to respond. Keep a record of all communication.

Step 2: If the organisation does not respond, submit a formal complaint to the Information Regulator at www.inforegulator.org.za.

Step 3: The Regulator will assess and may launch a formal investigation. They have the power to compel organisations to comply and impose penalties.

Penalties organisations face for POPIA violations:

- Administrative fines of up to R10 million
- Criminal prosecution which can result in imprisonment of up to 10 years

- Reputational damage from public enforcement notices

Checklist Activity: Spot the Compliant Privacy Policy

Privacy Policy Extract A:

"We collect your name, email address, and phone number when you register on our platform. This information is used solely to create and manage your account and to send you service-related notifications. We do not sell or share your information with third parties without your explicit consent. Your information is stored securely and will be deleted within 30 days of account closure. You may contact our Information Officer at privacy@company.co.za to request access to, correction of, or deletion of your personal information. You have the right to lodge a complaint with the Information Regulator of South Africa if you are not satisfied with how we handle your data."

Privacy Policy Extract B:

"By using our services you agree to our privacy policy. We collect information about you to improve your experience. We may share this information with our partners and affiliates from time to time. We reserve the right to update this policy at any time. For questions, contact us through the app."

Discussion: Extract A is compliant. It clearly states what is collected, why, how long it is kept, who to contact, and how to exercise your rights. Extract B is non-compliant. It uses vague language about sharing with "partners and affiliates", does not specify what information is collected or why, gives no retention period, provides no Information Officer contact details, and reserves the right to change the policy without notice.

PART B: KNOWLEDGE CHECK QUIZ

Question 1

A mobile app collects your location data every time you open it, even though the app only provides weather updates for your city. Which of the 8 POPIA conditions does this most likely violate?

A) Accountability

B) Processing Limitation

C) Security Safeguards

D) Openness

Question 2

Mandla wants to find out what personal information a company holds about him. Who within the organisation should he contact?

A) The CEO of the company

B) The company's marketing department

C) The Information Officer

D) The Information Regulator

Question 3

An organisation's privacy policy states: "We may share your information with selected partners from time to time for business purposes." Why is this statement problematic under POPIA?

A) Organisations are never allowed to share personal information with any third party

B) The statement is too long and should be summarised

C) The statement is vague and does not specify who the partners are or the purpose of sharing

D) Privacy policies do not need to mention third party sharing at all